

[doc. web n. 10086523]

Provision of October 17, 2024

Register of provisions

n. 621 of October 17, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by

Prof. Pasquale Stazione, president, Prof.

Ginevra Cerrina Feroni, vice president, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Secretary General Fabio Mattei;

HAVING REGARD to Regulation (EU) 2016/679 of the European

Parliament and of the Council, of April 27, 2016, concerning

the protection of natural persons with regard to the

processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing the

"Code regarding the protection of personal data",

which includes provisions for the adaptation

of national legislation to Regulation (EU)

2016/679 of the European Parliament and of the Council, of

April 27, 2016, concerning the protection of

natural persons with regard to the processing of personal data,

as well as the free movement of such data and repealing

Directive 95/46/EC (hereinafter the "Code");

HAVING REGARD to Legislative Decree No. 101 of August 10, 2018, containing

"Provisions for the adaptation of national legislation

to the provisions of Regulation (EU) 2016/679 of the

European Parliament and of the Council, of April 27, 2016,

concerning the protection of natural persons with regard to the

processing of personal data, as well as the free movement of such

data and repealing Directive 95/46/EC";

HAVING REGARD to Regulation No. 1/2019 concerning

internal procedures with external relevance,

aimed at carrying out the tasks and

exercising the powers assigned to the Guarantor for the

protection of personal data, approved by

resolution No. 98 of April 4, 2019, published in

G.U. No. 106 of May 8, 2019 and in www.gpdp.it, doc. web

n. 9107633 (hereinafter "Guarantor Regulation No.

1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary

General pursuant to Article 15 of the Guarantor Regulation

No. 1/2000 on the organization and

functioning of the office of the Guarantor for the

protection of personal data, doc. web n. 1098801;

Rapporteur Dr. Agostino Ghiglia;

PREAMBLE

1. The breach of personal data

On XX, the SS. Antonio e Biagio e Cesare Arrigo Hospital-University Company, hereinafter

referred to as "Company," notified the Authority, pursuant to Article 33 of the Regulation, of a personal data breach - supplemented with notes from XX and XX - concerning a cyberattack on the Company's information systems caused by a ransomware malware "Ragnar Locker." Given the high number of affected individuals involved and the nature of the personal data subject to the breach, it was necessary to investigate the circumstances in which the aforementioned personal data breach occurred, as well as the security measures adopted, through an inspection activity against the Company in January 2024.

2. The facts

The personal data breach was described both in the notification made to the Authority, in several phases, pursuant to Article 33 of the Regulation, and during the aforementioned inspection activity. In particular, the following was found.

2.1. The notification of the breach to the Guarantor

Preliminarily, with the notification of XX, the Company stated that "the Company's infrastructure was the subject of a cyberattack by a group that released a ransomware called 'Ragnar Locker'" (see notification of XX, section XX, point XX). Subsequently, the Company updated the information regarding the breach, stating that "on the night between XX, approximately starting from XX hours and XX hours the following day, the IT infrastructure of the hospital Company (...) saw many of the PCs on its network invaded by a message notifying of a hacker attack by a group called 'Ragnar Locker.' The message states that the content exfiltrated from the shared folders would be sold to third parties if there was no contact via the TOR channel for instructions within three days. It is specified that the attack was limited to only the part of the Hospital's infrastructure that contains data shared by users, namely the files shared via file servers. The healthcare applications installed at the central company data center were not attacked. No software or services to users were violated. Therefore, the hospital did not suffer disruptions or limitations in the exercise of its institutional function" (see notifications of XX and XX, section X, point X).

to the use of the ICT infrastructure, including guidelines for the management of user accounts and access privileges. The Company has also implemented a series of security measures, including firewalls, antivirus software, and regular security audits, to protect sensitive data and ensure compliance with data protection regulations" (v. verbale del XX, pag. XX).

3.3. Formazione e sensibilizzazione

In merito alla formazione e sensibilizzazione del personale, l'Azienda ha dichiarato che "sono stati organizzati corsi di formazione periodici per il personale, con particolare attenzione alla sicurezza informatica e alla protezione dei dati personali. Tali corsi hanno incluso moduli specifici sulla gestione dei dati sensibili e sull'uso sicuro delle tecnologie informatiche" (v. verbale del XX, pag. XX).

4. Conclusioni

In conclusione, l'Azienda ha ribadito che "nonostante l'attacco subito, non si sono registrati impatti significativi sui servizi erogati e che le misure di sicurezza implementate hanno contribuito a limitare i danni. Tuttavia, si è impegnata a rafforzare ulteriormente le proprie politiche di sicurezza e a migliorare la formazione del personale per prevenire futuri incidenti" (v. verbale del XX, pag. XX).

regard to the password policy and the correct use of the file server. On April 3, 2023, the "Cybersecurity Decalogue" was also transmitted to all personnel via the company intranet; (additionally, a) note (...) was sent to all staff in September 2022, which referenced part of those guidelines with particular regard to the correct use of the file server; that "it has a quality management system certified ISO 9001, through which any potential issues in the area of privacy are also detected thanks to the customer satisfaction process and internal audits. In this regard, internal auditors have been specifically trained, and the audit model of the quality management system is taken into account by the DPO team" and that "the configuration of workstations (PdL) at the time of the incident included 70% of the XX operating system and 30% of the XX operating system. Following the breach, all workstations were progressively replaced through the procurement plan for new PdL under the CONSIP agreement. The antivirus software used for the PdL and servers (XX) did not have differentiated configurations for the different operating systems and allowed for profiling of protection levels (more or less elevated). The expected level of protection was lower on XX machines and, in particular cases, on some XX machines, considering the potential negative impact on the operation of the machine and its performance also due to the existing hardware resources (...) perimeter security services related to the management of the same Firewall were guaranteed under the CONSIP SPC 2 framework agreement; no security measures were adopted to protect and limit access to the memory area used by the lsass.exe process (Local Security Authority Subsystem Service - LSASS) such as hardening activities on the operating system (e.g., correct configuration of the related registry key. (...)) Hitachi servers were used, acquired through direct assignment with management and maintenance by external resources. Subsequently, a project for the technological upgrade of the data center and backups was activated, tested in March 2023 (...); that "at the time of the personal data breach, the awarding of the tender for the realization of the aforementioned project was ongoing" (see minutes of XX page XX and XX pages XX and XX).

Regarding the computer authentication procedures used for VPN access and the workstations in place at the time of the breach and the password policies provided for the different types of users, the Company, during the inspection activities, stated that:

- "there was no multi-factor authentication (MFA) procedure for remote VPN access, which was used before the pandemic exclusively by suppliers and, subsequently, also by employees for the 'remotization' of the PdL, after acquiring the list of personnel to be authorized. The 'maintenance' accounts were often generic, not individual, with maximum administrative privileges. Following the incident, actions were taken: to activate MFA, to certify the VPN, and to identify named accounts (through specific forms), in compliance with the principle of 'least privilege'";
- "although guidance had been provided to staff regarding password selection, inspired by good industry practices, no configuration of the systems was in place to incorporate such guidance. Users performing administrative functions used differentiated accounts, depending on whether it was a personal domain account or an account with administrative privileges. In the latter case, the credentials, which did not have a specific password policy, were generally shared among the various administrators" (see minutes of XX, page XX).

During the inspection activities, regarding the security measures in place at the time of the personal data breach, related to network segmentation, the Company stated that "the network was essentially flat, there was no logical or physical segmentation, and the network infrastructure was managed by external personnel within the services acquired through the aforementioned framework agreement; since December 2022, the Company has acquired an internal resource as a senior system administrator specifically to manage the design and review activities of the network. Currently, segmentation is planned for new installations and the adjustment of the existing infrastructure and over 6000 connected devices is underway. At the organizational level, starting from July 2023, the clinical engineering unit has been merged into the new complex organizational unit 'ICT and Technological

Innovation' for integrated and more efficient management of applications and medical devices" (see minutes of XX, page XX).

Regarding the technical and organizational measures adopted to ensure the availability and resilience of the systems and processing services, as well as the timely restoration of the availability and access to personal data in the event of an incident, the Company stated that "the infrastructure dedicated to backup performed a periodic screenshot (typically weekly) of the virtual machines without a retention policy" (see minutes of XX, page XX).

Regarding the monitoring tools for security events used for real-time detection of security incidents, with particular...

reference to monitoring software, the Company has represented that "following an assessment carried out in the early months of 2022 [...] it was found necessary to equip itself with: an asset management system; a SIEM, along with a 24/7 SOC service with a SOAR component (orchestration of alerts and event correlation); SSL certificates for the domains registered in the name of the Company and new firewalls" (see minutes of XX, p. XX).

From the documentation acquired during the activity, it emerges that at the time of the attack there were numerous vulnerabilities at the network level ("there is no segmentation at level three of network traffic. (...) Workstations (and) servers are not differentiated at the network level. (...) Many (users) had maximum administrative rights. The database (...) is a XX that presents many security flaws. (...) Escalation techniques can be implemented. Various obsolete communication protocols are still active. (...) VPN accounts were connected to the domain and those of the companies were also domain administrators") (see attachment 1 to the minutes of XX, pp. XX and XX).

Regarding the methods by which security incidents are communicated to the various parties involved and the process for managing security incidents in the event of a personal data breach, the Company specified that "at the time of the personal data breach, there was an operational instruction attached to the Regulation on the use of IT tools, (...) concerning incident management with a focus primarily on events reported by perimeter security systems and aimed mainly at IT personnel"; that "the Company established through resolution (...) a privacy group composed of members from various Company structures, operational at the time of the personal data breach"; that "it equipped itself with a software tool called "XX" for the management of personal data protection processed by the Company" and that "it prepared a data breach procedure, included in the quality system and made known to all employees XX and also available on the intranet" (see minutes of XX, pp. XX and XX).

In any case, it was highlighted that "for a year and a half prior to XX, beyond the emergency event, the issue of cybersecurity had been the subject of planning that saw the Company engaged in a complex effort to enhance the security infrastructure and improve awareness of the risks related to cyber attacks towards users. (...) In November 2021, among the first in Piedmont, the Company also conducted a survey, based on 110 questions related to 9 domains and 35 control areas, to quantify the level of risk exposure of the main sector areas and to compare them with industry benchmarks. The analysis also suggested, based on experience in cybersecurity, companies with similar risk levels and guidelines for investment planning." "From January 2022, starting from the analysis of the adequacy level to the minimum standard levels of AgID guidelines no. 2/2017, we identified already in the first quarter of 2022 the list of remediation to achieve full compliance with at least the minimum set and 95% of the standard set by 2023. This planning then culminated in the document "P 02_Plan for compliance with minimum AgID measures" of June 2022, a sector procedure of the ICT Area that is part of the documentary corpus of the Quality Management System" (see attachment 1 to the minutes of XX, pp. XX and XX).

4. Measures adopted following the breach

4.1. Notification of the breach to the Authority

With reference to the measures adopted following the breach, the Company represented that "at a preventive level (the access rules to the internet via the firewall have been) further restricted", "access as an administrator to external users outside the company network (typically the maintenance

personnel of application suppliers) has been limited”, “joint analysis has been initiated with the antivirus supplier and with the network management partner and related active devices to verify potential vulnerabilities within their competence or containment actions” and, subsequently, that “the operational countermeasures implemented after the attack were as follows: two-factor authentication system on every service accessible from the outside with particular reference to VPN, Email, cloud antivirus server, and cloud antivirus clients. Domain management through XX (in particular, administrator users have been reviewed and thus considerably reduced, calibrating access based on the activities that users must perform) Firewall management Communications and notifications to the relevant authorities (Postal Police, ACN, immediate communication to the general management and to the interested operators with an operational checklist of actions to be taken)” (see notifications of XX and XX, section XX, point XX).

4.2. Inspection activities

During the inspection activities, the Company declared that “following the report of the presence of the ransom note by the IT service, the DPO and the general management were contacted via an email containing information about the type of breach suffered, the content of the ransom note (request for ransom for the published data). In

The following report was made through the dedicated service of CSIRT (ACN) and a complaint was filed with the postal police. Several communications were also sent among the directors of the involved structures as well as to all personnel. (...) Subsequently, an additional phase of in-depth analysis was carried out (...); it was verified that the attacker was not persisting in the network while remaining passively connected; the backdoor was dismantled, and no further evidence of persistence was found; that the “levels of protection (of workstations) have been progressively raised” and that “the backup of data and systems (mailboxes, file servers, management systems, etc.) has been consolidated with a strategy of type [OMISSIS]” (see minutes of XX, page XX).

Regarding the file server involved in the personal data breach, the Company stated that “it is in an advanced phase of decommissioning and is currently accessible in read-only mode. This server has been replaced by a new file sharing infrastructure, with permissions and authorizations related to each reference structure that has a folder named with the code of the relevant responsibility center. The director of the structure has all permissions on this folder (e.g., read, write, share, etc.) and manages the permissions of their collaborators. In addition to this environment, the file sharing tool in XX, XX is available” (see minutes of XX, pages XX and XX).

Regarding technical and organizational measures, the Company also represented that “the structural enhancement plan for IT services originated following the assessment carried out at the beginning of 2022 (...) in which the main measures to be adopted were indicated to mitigate the identified criticalities, indicating the hypotheses for the termination of activities (end of 2022) useful also for reallocating the necessary economic investments. Following the attack, the priorities of the plan were reviewed, with particular reference to: revision of user permissions, reorganization of the corporate XX (new domain controllers created, reduction of the number of users belonging to the admin group restricted only to system administrators, policy review), network segmentation plan both logical (VLAN) and physical for the various structures, purchase of a XX load balancer for managing incoming and outgoing traffic, load management, and to implement the VPN with MFA. In 2023, thanks to PNRR funds: the SIEM and SOC services were activated, a WAF was acquired, technological upgrades of the devices and infrastructure of the VOIP XX switchboard were carried out, the antivirus platform was updated (XDR module for endpoints and servers), a methodological support project was launched for the clinical engineering structure for the analysis of the security posture of connected electromedical devices and the management of the lifecycle of the devices, in order to comply with security requirements in the various phases (e.g., purchase, installation, maintenance); an XX asset management system was also acquired.” It was also stated that “an e-learning training path on cyber awareness topics has been activated for all operators, in multiple modules with a final learning test, which has seen, so far, the active participation of about 45% of the staff. To make this measure fully effective, the aforementioned training activity has been included in the 2024 corporate objectives.

Furthermore, the Company has joined the training platform "Syllabus," made available by the Department of Public Function of the Presidency of the Council of Ministers," "which provided internal operational instructions for the correct reset of passwords and, shortly, a portal will be available to automatically reset passwords in accordance with the rules established in the password policy," providing the document "Measures for Cybersecurity AOU AL – Milestone of the main interventions regarding risk mitigation actions related to vulnerabilities in the Company's IT security" (see minutes of XX, pages XX and XX).

Finally, regarding the strategic plan, the Company "clarified that the current management began operating at the end of 2021, during the pandemic. This strategic plan (...) is the result of the integration of the previous plan with two new directions: "return to normality" and "digitalization, cybersecurity, and privacy." Since April 2022, Eng. (...) has taken responsibility for the IT structure, expert senior professionals have been acquired, and the privacy service has been strengthened and reorganized. A cross-functional group (IT, DPO, quality manager) has also been created, coordinated by the administrative management" (see minutes of XX, page XX).

5. Evaluations of the Department on the processing carried out and notification of the breach pursuant to Article 166, paragraph 5 of the Code

Regarding the described case, the Office, based on what was represented by the data controller in the notification of the breach and what emerged during the inspection activity, as well as subsequent evaluations, notified the Company, pursuant to Article 166, paragraph 5, of the Code, the initiation of a procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation, inviting the aforementioned data controller to produce defensive writings or documents or to request to be heard by the Authority.

(art. 166, paragraphs 6 and 7, of the Code; as well as art. 18, paragraph 1, of Law No. 689 of November 24, 1981). In particular, with act No. 0059959 of May 17, 2024, the Authority deemed that the Company had violated the principle of "integrity and confidentiality," as per art. 5, paragraph 1, letter f), of the Regulation, as well as the obligations regarding the security of processing (art. 32 of the Regulation). The same Company submitted its defensive memoranda, pursuant to art. 166, paragraph 6, of the Code. In particular, with a note dated XX, accompanied by substantial documentation, it clarified what was expressed in the notifications of violations and during the inspection activity, stating that:

- in relation to the failure to adopt adequate measures to promptly detect the violation of personal data, "even though at the time of the events it did not yet have an integrated SIEM (security information and event management) and a SOC (Security Operations Center) service for 24/7 monitoring of alerts, the Company was equipped with a monitoring service for the logs of the corporate firewalls, as part of its adherence to the CONSIP Framework Agreement SPC Cloud lot 2, concerning: 'Cloud Computing services, security, development of portals and online services, and application cooperation for public administrations – ID SIGEF 1403', awarded to the RTI composed of XX (lead contractor) and IBM SpA - SISTEMI INFORMATIVI S.r.l. - XX Spa (subcontractors), approved by Resolution No. 857 of 09/13/2017, later renewed with Executive Determination No. 2032 of 12/29/2021 until the end of 2023" (...). In particular, the service in question provided, through the use of the "XX" solution and "XX" services (provided by XX as a subcontractor within the awarded supply in which XX was the winning bidder), the necessary features to identify threats to the corporate network and network analysis activities in line with changes in the network or the Company in general. Furthermore, from the early days of XX, about three weeks before the notification of the attack, the XX solution was installed, a centralized platform for the aggregation and real-time analysis of telemetry data for the detection and compliance of threats. XX collected data on events from the firewalls and from some of the machines in the corporate Data Center, assisting the reconnaissance carried out with the support of the ACN team following the report of the attack to reconstruct the lateral movements of the attackers. Following the attack, the investment for the installation of the SIEM (Security information and event management), a system for managing security information and events that, by analyzing the logs related to the devices connected to the network infrastructure, allows for the management and

processing of operational countermeasures to potential threats and vulnerabilities, was then implemented. The investment had already been planned at the time in the corporate programming context as part of the interventions eligible for funding under measure 1.1.1 Digitalization DEA, Mission 6 of the PNRR”;

- in relation to the failure to adopt adequate measures to ensure the security of networks, “at the time of the attack, the corporate network was structured on a single native VLAN, also used for client and/or server data traffic. Aware of the criticality that such a configuration represented, the Hospital Company, as part of the development of the strategic plan 21 – 24 – strategic area cybersecurity (...), initiated a mobility procedure in March 2022 (...) with specific systemic cybersecurity skills, to coordinate the assistance and maintenance services of the corporate network and its perimeter security components. This role in the Company had not been covered since 06/17/2020,” (...) and the definitive hiring of the candidate deemed most suitable for experience and competence was only possible from XX, practically less than a month before the notification of the attack suffered. It should be emphasized that, immediately after the attack, and precisely thanks to the project competence of the senior system administrator role finally integrated into the organizational structure of the ICT Area, a remediation plan was prepared based on the following three conceptual pillars:

- granular segmentation, with a logical network for each floor cabinet, a VLAN for medical devices differentiated by specialty of use (one for radiology biomedical devices, one for laboratory medical devices, one for radiology workstations, one for general medical devices) and dedicated VLANs for services that could somehow jeopardize corporate security through direct internet exits, typically for remote assistance services or to implement monitoring on cloud platforms.
- Securing communication between one VLAN and another, through appropriate ACL (Access Control List) filters to limit traffic. The corporate infrastructure allows the use of the same ACL for each VLAN to enhance performance. It was crucial to prohibit RDP (Remote Desktop Protocol) traffic to central servers, except for those authorized (for example, terminal servers).
- Implementation of an automatic VLAN management system, through the implementation, [OMISSIS], to authorize access to the corporate network only for authorized machines. With this mechanism, it is possible to isolate unauthorized ones and activate blocking policies for those ports of resulted compromised by an unauthorized MAC address”;

- “such planning (...) is in the implementation phase”;

- in relation to the computer authentication procedure, “the proliferation of the number of enabled VPNs during the two-year management of the COVID-19 pandemic (activation of remote working stations) has certainly worsened the security posture of the network infrastructure. That said, it is undeniable that, at the time of the attack, the active VPNs did not have two-factor authentication. In any case, it is important to highlight the immediate responsiveness of the infrastructure immediately after the attack notification, implementing the MFA (Multi-Factor Authentication) system already within the first half of January, [OMISSIS]. Furthermore, a redesign planning of the VPNs has been prepared with the logic of:

- creating a separate LDAP server and implementing ACL for each user/company, so that access is governed by the Role-Based Access principle.
- Implementing a series of accesses via terminal server to the main web application services of the hospital, managed by the load balancer;
- Initiating training and informational activities for users, in order to raise awareness among users about the importance that not all services provided on the local network can be accessed outside the corporate network”;

- in relation to the obsolescence of the base software installed on some processing systems, “although the patch update related to the CVE indicated in the attached report following the data breach notification occurred after the attack itself, to date there is no evidence that the vulnerability found on the firewall was the direct cause of infiltration into the corporate network. On the contrary, it is much more likely that there is not a single direct cause, but that it was the combined effect of the co-causes already stated in the aforementioned report that determined the vulnerability. Despite this, aware of the importance of acquiring an inventory & asset management system that would allow for the

management of updates and vulnerabilities of the installed base, the Company, with an order on the MEPA platform (Electronic Market for Public Administration) in September 2022 (therefore a few months before the attack), had initiated the acquisition process and subsequent installation of a platform for the discovery of all devices connected to the network, the assessment of the CVSS risk index of the vulnerability, and the management of the CVEs related to each of the assets themselves, OMISSIS”;

- “the current strategic direction, which took office in AO AL in June 2021 in a context still characterized by the exceptional nature related to the pandemic emergency, has strongly desired a decisive change of pace in the field of digitization and cybersecurity. This emerges first and foremost from the revision of the Strategic Plan (resolution no. 196 of 29/04/2022 – approval of PIAO), with which a signal of substantial continuity with the previous plan was intended on one hand, and on the other hand, a signal of strong discontinuity on two aspects deemed fundamental: 1. Digitization and skills, and a strong push towards cybersecurity and privacy (Strategic Area 1 - “C - Skills and digitization”); 2. preparatory actions for exiting the pandemic and returning to “normality” (Strategic Area 2 - “O - Order after the storm”). Within the two implemented strategic areas, it is digitization that the company has decided to set as a priority strategy, and among the main directives, “Cybersecurity, transparency, and privacy” assumes significant relevance”;

- in relation to the main actions taken and the organization and resources in the ICT Area, “during 2022 and with greater completeness during 2023, AO-AL has consolidated both the technological components of its network infrastructures (both data and voice) and the skills of the personnel involved. One of the first actions initiated at the beginning of 2022 concerned the profound reorganization of the ICT area. Starting from the change at the top of the structure (...) the structure was strengthened, with the hiring of an additional analyst manager and the hiring of a Technical Collaborator category D expert in networks and cybersecurity. With the new act, the S.C. “ICT Area” also acquired responsibility for the SS Clinical Engineering, changing its name to S.C. “ICT and Technological Innovation” and thus creating the conditions for a complete integration between two worlds that are now interconnected and integrated in the digital realm. The professional role of “ICT infrastructure and cybersecurity management” was also identified and entrusted, from January 2023, to a manager of the ICT structure the task of “Management and optimization of corporate software installations”;

- in relation to the main actions taken and the organization and resources in the Privacy Area, “with resolution no. 420 of 27/07/2021, the “Corporate Privacy Working Group” was established with specific tasks expressly indicated and “with the revision of the corporate act, the new Privacy Service was created, in staff to the strategic direction” which is specific determined aspects;

- “a collaboration has been initiated with CSI Piemonte (an in-house company of the Piedmont Region of which the AOU is a member) for ‘support activities in the field of GDPR’ (...) in the application of the principle of ‘Accountability’ provided by REGULATION (EU) 2016/679”, regarding specific expressed needs;

- in relation to the nature, severity, and duration of the violation “the compromised system is that of shared folders in environment XX of the PdL (Workstations) network of the Hospital Company. The shared folders constitute a corporate system in which employees can store documents, spreadsheets, presentations, and more generally any file useful for the organization of work. Theoretically, within this system, there should only be documents for individual productivity purposes (therefore files for the organization of departments, work documentation, but not related to patient activities), while health data related to patients' clinical pathways should only be managed through the corporate applications that generate electronic medical records. In practice, however, health data (e.g., copies of reports, examinations, etc.) were also present, although it should be specified that these were unindexed files, more akin to ‘working copies’ than elements for managing treatments”;

- “the issue is therefore linked to a more conscious use by hospital employees of the File Sharing environment and IT infrastructures in general and the associated risks regarding non-compliance with the principles of protection of health data processing and cybersecurity. In this regard, see the section concerning communications sent at least monthly by the Management to all medical staff about the

reminder to use the file server for its intended purposes in the chapter dedicated to the organizational measures implemented following the notification of the attack. In any case, the days following the attack (starting from January 2, 2023) were spent analyzing, with the support of the National Cybersecurity Agency (ACN), and the support of a SOC (Security Operations Center), immediately engaged by the I.C.T. service of the Company for support in log analysis and remediation activities, the movements of the attackers within the Company's network infrastructure systems, in order to identify the method of initial access";

- "the situation at AO AL is part of a national context well described by the authoritative CLUSIT 2024 report, in which the healthcare sector in 2023 was the fourth most affected sector by successful cyberattacks in the public domain, after Manufacturing, Professional/Scientific/Technical, and ICT, with a percentage of 9% of the total recorded incidents. This percentage has quadrupled compared to the analysis period of the same report from the previous year, in which the healthcare sector constituted 2.2% of the attacks suffered by the relevant IT infrastructures";

- "the AOU (...) has made all its email channels and toll-free number available to manage any possible contact with those affected by the breach of confidentiality. To date, no reports, appeals, complaints, or formal notices have been received. From an infrastructural point of view, starting from day XX, the date on which a DFIR (Digital Forensic & Incident Response) team from the National Cybersecurity Agency was deployed to the Alessandria Hospital Company to provide technical support in the analysis and restoration of services, and for the approximately 30 days following, the following operations were introduced as immediate operational countermeasures to mitigate the effects of the breach: • Blocking data traffic outside Italy; • two-factor authentication on every service accessible from the outside (MFA – Multi-Factor Authentication technology), with particular reference to access to corporate email accounts and access to the corporate network from the outside via VPN (Virtual Private Network); • Activation of two-factor authentication for the antivirus system console, both on the endpoint and server side, which was not active at the time of the attack; • Consolidation of the corporate XX system, drastically reducing, first of all, the number of users in the domain admin group, [...] thus excluding service users as well. Furthermore, the copy of the folders was restored, the pre-existing domain controller was eliminated, and two new domain controllers were created in an environment with an updated operating system to XX for read and write, plus two read-only domain controllers, placing the first in a new VLAN with dedicated DNS services. The password XX was reset twice. With the XX application, the main vulnerabilities were monitored daily, and the relevant security modifications were made. This activity was carried out in collaboration with the technical support of the ACN technical team";

- in relation to the technical and organizational measures implemented pursuant to Articles 25 and 32 of the Regulation: prior to the attack, "beyond the emergency event, the issue of cybersecurity had been the subject of planning that saw the Company engaged in a complex operation to enhance the security infrastructure and to

improving awareness of the risks associated with cyber attacks towards users already during the period between the end of 2019 and the beginning of 2022. Below are the main activities from which the attention and planning efforts are evident:

- December 2019: acquisition, in a logic of technological refresh of the previous solution, of a security platform for the protection of Endpoints, Servers, and mobile devices with functionalities of Antimalware, Firewall, Intrusion Prevention System, Encryption, and Application Control. The identified solution, the products "XX" is included by Gartner in the famous report titled "Magic Quadrant for Endpoint Protection Platforms" in the section reserved for "Leader" technologies, the upper right quadrant (see in this regard the managerial determination no. 518 of 30/03/2020 ...);

- July 2020: activation of the FAD training course "GDPR Course - EU Regulation 2016/679 – and IT Security," included in the corporate training plan for the years 2020 to 2024 with 4 ECM credits. The course was configured as a basic course for all employees and external parties available on the ECM Piemonte platform;

- July 2021 in accordance with and pursuant to Article 36 of the GDPR, conducted with XX an activity of "data protection impact assessment" (...). The DPIA aimed to support the data controller in defining strategies for the protection of the analyzed data (in particular DSE, processing of data related to the

health of patients and users of internal medicine and emergency services, management control). The analysis also highlighted the necessary security and technical measures to mitigate the risk that were included in a risk treatment plan and a short-term action plan to ensure the protection of personal data concerning the processing subjected to impact assessment;

- November 2021: participation, as part of a regional initiative to analyze levels of cyber risk for insurance profiling as the leading company, in an assessment promoted by XX. The assessment activity was based on the completion of the questionnaire [OMISSIS]. The cyber risk assessment, despite its partial randomness, having been based solely on the responses to the questions of the questionnaire and given the complex nature of the topic, nonetheless allowed for quantifying the level of exposure to risk of the main sector areas and comparing them with sector benchmarks.

Furthermore, (...) the Company received in the communication of sending the report in question, confirmation that the path undertaken represented a significant change of pace and highlighting that “many of the activities recommended within the report XX are in line with the mitigation path initiated, demonstrating excellent awareness and willingness to intervene to improve the situation”;

- December 2021 - January 2022: activation of a training path, now in its third edition in 2024, of cyber awareness, that is, conscious use of IT infrastructures and tools to develop in employees a clear awareness of cyber risks through the advanced use of multimedia systems and the real involvement of all users;

- January 2022: initiation of an assessment, concluded in August 2022, of the level of vulnerability (“Vulnerability Assessment”), in order to plan the main corrective and consolidation actions. In particular, the study allowed for identifying the vulnerabilities present on the target systems and defining a recovery plan, based on the critical issues of the identified security problems and thus giving the correct priority to patching activities. See in this regard the document “Vulnerability Assessment 2022” (...). This recovery plan was then integrated, in June 2022, into the sector procedure of ICT services, developing a document, subsequently integrated into the Quality Management System of the service itself, which aligned these countermeasures with compliance with the standard security measures contained in the AgID Guidelines as per Circular of April 18, 2017, no. 2/2017. The document also contained a rough planning of the consolidation activities and corrective actions for the resolution of the detected anomalies by the third quarter of 2024. See in this regard the procedure “P 02_Plan for adapting AgID security measures”;

- March 2022: (...) planning of investments PNRR Mission 6 component 2, investment 1.1.1, where investments were planned to acquire know-how and technologies necessary to enhance the infrastructural and application security of hospital systems” and “revision of the Sector Procedure of the ICT Area and simultaneous dissemination to the corporate user population. The communication also contains a concise yet comprehensive summary of the best practices to be adopted for greater awareness on the part of the company’s employee users in the use of credentials and IT tools in general (...);

- August – October 2022: integration into the document corpus of the Quality Management System of the ICT Area of the operational instructions, developed (privilege)”, l’azione risolutiva è stata: “è stata effettuata una revisione completa dei privilegi degli utenti, con l’obiettivo di garantire che ogni utente abbia accesso solo alle risorse necessarie per le proprie funzioni lavorative. Sono stati implementati controlli regolari per monitorare e rivedere i privilegi degli utenti, assicurando che eventuali modifiche siano documentate e approvate secondo le politiche aziendali”;

- in relazione alla vulnerabilità riscontrata a valle dell’attacco, avente ad oggetto la “mancanza di formazione e sensibilizzazione del personale riguardo alla sicurezza informatica”, l’azione risolutiva è stata: “è stato avviato un programma di formazione obbligatoria per tutti i dipendenti, con sessioni regolari di aggiornamento e sensibilizzazione sui rischi informatici e sulle migliori pratiche da adottare per garantire la sicurezza dei dati aziendali. Sono stati distribuiti materiali informativi e sono state organizzate simulazioni di attacco per testare la prontezza del personale”;

- in relazione alla vulnerabilità riscontrata a valle dell’attacco, avente ad oggetto la “mancanza di un piano di risposta agli incidenti”, l’azione risolutiva è stata: “è stato redatto un piano di risposta agli

incidenti che definisce le procedure da seguire in caso di attacco informatico. Questo piano include la designazione di un team di risposta agli incidenti, la definizione dei ruoli e delle responsabilità, e le procedure di comunicazione interne ed esterne. Sono stati effettuati test regolari del piano per garantire la sua efficacia e aggiornato in base alle lezioni apprese da incidenti passati”;

- in relazione alla vulnerabilità riscontrata a valle dell'attacco, avente ad oggetto la “mancanza di monitoraggio continuo della rete”, l'azione risolutiva è stata: “è stato implementato un sistema di monitoraggio continuo della rete, in grado di rilevare attività sospette e anomalie in tempo reale. Sono stati configurati avvisi automatici per informare il personale IT di potenziali minacce, e sono stati effettuati audit regolari per garantire l'efficacia del sistema di monitoraggio”;

- in relazione alla vulnerabilità riscontrata a valle dell'attacco, avente ad oggetto la “mancanza di backup regolari e sicuri dei dati”, l'azione risolutiva è stata: “è stata implementata una strategia di backup che prevede backup regolari e sicuri dei dati critici, con memorizzazione in luoghi sicuri e separati. Sono stati effettuati test regolari per garantire che i backup siano completi e ripristinabili in caso di necessità”;

- in relazione alla vulnerabilità riscontrata a valle dell'attacco, avente ad oggetto la “mancanza di aggiornamenti regolari del software e delle applicazioni”, l'azione risolutiva è stata: “è stato istituito un programma di gestione degli aggiornamenti che prevede l'installazione regolare di patch e aggiornamenti di sicurezza per tutti i sistemi e le applicazioni utilizzate dall'azienda. Sono stati effettuati audit regolari per garantire che tutti i sistemi siano aggiornati e protetti contro le vulnerabilità note”.

privilege), since about 130 users had the highest administrative rights,” the resolution action was: “the domain administrators were reduced to four, corresponding to the system administrators of the infrastructure”;

- in relation to the vulnerability identified following the attack, concerning the “lack of an Asset and Inventory management system for the management and identification of machines, including offline,” the resolution action was “during the attack, XX was used. Currently, the Company uses solution XX”;

- in relation to the vulnerability identified following the attack, concerning the “lack of organizational procedures for the inclusion of machines in the network or a form for managing the underlying VPN requests and identification rules,” the resolution action was: “the Workstation regulation was revised and a form and process for the retention of the form and requests was created”;

- in relation to the vulnerability identified following the attack, concerning the “lack of a procedural link between the database of the application that manages the employee registry and the assignment of company work tools proportionally to the contractual classifications, and therefore to the levels of responsibility provided for each profile,” a “portal was created that connects the personnel registry to network accounts. It provides privileges and licenses based on the role”;

- in relation to the vulnerability identified following the attack, concerning the “lack of a centralized system for managing user accounts and consequently for managing passwords,” a “portal was created that connects the personnel registry to network accounts. It provides privileges and licenses based on the role”;

- in relation to the vulnerability identified following the attack, concerning the “suboptimal organization of the identity management system XX, with many of the users from the employee registries included in multiple groups with various access privileges, with the possibility of implementing escalation techniques,” the action taken was “the system of groups and associated authorizations was revised with the support of application XX”;

- in relation to the vulnerability identified following the attack, consisting of the fact that “obsolete communication protocols, including smbv1 and NTLMv1, were still active,” the action taken was “90% of the servers with smbv1 protocols were eliminated and processes were initiated with suppliers for the remediation of the rest”;

- in relation to the vulnerability identified following the attack, consisting of the fact that “for the management of assistance and maintenance activities for many applications, service users were configured with administrator privileges, making it impossible to reduce their privilege level without interrupting the availability of related services,” and that “many user accounts for VPN access granted to companies providing assistance services for the applications were connected to the domain and/or also domain administrators,” the actions taken were “created double VPN authentication and XX” and “remediated domain administrators”;
- “regarding structural investments, beyond the operational countermeasures to contain the exposures identified following the attack, the AOU of Alessandria has initiated investments aimed at activating control services and acquiring perimeter security systems” (...) that have affected numerous profiles;
- in relation to the organizational measures implemented following the notification of the attack, “first of all, a series of communications were initiated both internally and to the relevant authorities as specified below: • immediate notification to the Postal Police and the ACN; • preliminary notification of the data breach to the Supervisory Authority within 72 hours as per Regulation; • immediate communication to the General Management and from there to the relevant healthcare operators with an operational guideline of actions to be immediately implemented to counter the risk. In this regard, the communications sent by XX company regarding: 1. the invitation to all employees to restart company PCs and follow the instructions for generating a new access password according to the best practices reiterated in the company regulation. See in this regard the email from XX of the Director of Structure Area I.C.T. (...); 2. contact with the technical representative of the company from whose generic user account for assistance activities on the hematology application installed on the servers of the AOU of Alessandria the access movement of the attackers was detected, as highlighted in the report produced by the ACN team. See in this regard the email from XX of the Director of Structure Area I.C.T. (...); 3. Communication to all employees of the General Management containing provisions on cybersecurity (...); 4. communication to all employees updating on the ongoing recovery and consolidation activities following the attack (...); 5. revision of the company regulation, formally approved with Resolution of the General Director no. 150 of XX on the correct use of the I.C.T. infrastructure of the AOU of Alessandria and related information to all employees (...); 6. creation of the new corporate File Sharing infrastructure and new provisions regarding its use with information provided to all employees (...); 7. further sharing of the new corporate regulations and a reminder for the activation of accounts for the new corporate File Sharing system for the hospital users (...); 8. Communication to all employees of the General Management containing provisions on cybersecurity (...); 9. further reminder for the activation of accounts for the new corporate File Sharing system for the hospital users (...); 10. Communication to all employees of the General Management containing reminders to comply with provisions on cybersecurity (...); 11. Activated "lock" functionality of XX and sent information to the hospital users (...); 12. Reporting of other phishing attacks (...); 13. Initiated a massive communication campaign aimed at employees regarding "cybersecurity"; - "regarding organizational and procedural measures: the corporate regulations have been updated to include provisions for the secure use of the Company's ICT infrastructure, (...) "Approval of corporate regulations 2023 for the use of ICT services." This revision introduces new criteria for the profiling of corporate accounts according to the principle of least privilege, updates the request forms for accounts, defines the new access rules for the new File Sharing system and corporate email, exemplifies the access methods to the VPN with MFA (Multi-Factor Authentication) technology. It also reiterates the conscious use of access passwords and their constant review according to best practices for generation to avoid them being trivial and easily identifiable"; - "appropriate operational instructions and guidelines have been prepared for the integrated management of updates of electromedical devices and for the periodic control of vulnerabilities from the recently acquired MDSP platform"; - "contractual attachments have been prepared for current and future procurement initiatives of applications and electromedical devices to be connected to the network in such a way as to manage, already in the drafting phase of the tender specifications or in the definition of the Purchase Order, informational elements such as security process requirements, initial risk determination of the device, communication scheme"; - "during the

inspection activity (...), a substantial series of documentary supports was gathered to accurately reconstruct the event of XX, meticulously following the collaborative requests of the officials and incorporating their indications to confirm or implement all necessary steps for the overall and complete assessment of the activities undertaken to resolve the issues underlying the hacker attack and facilitate the correct determination of the consequences and impacts on personal data and the rights and freedoms of potentially involved parties. The Company has also maintained a constant collaborative relationship with ACN (...); - "the categories of data impacted by the breach include personal data (name, surname, gender, date of birth, place of birth, tax code), contact data (postal or email address, landline or mobile phone number), access and identification data (username, password), health-related data for suppliers and patients as well as employees. Regarding employees, the impacted data consists of documentation related to the economic and regulatory activities concerning them and any additional personal content stored in the file server folders"; - "the Company (...), has acted in recent years in a context of particular critical conjuncture: • The SSR of the Piedmont region only exited the recovery plan conducted in collaboration and under the supervision of the MEF, known as the "Massicci Table," in 2017, which resulted in a significant contraction of current expenditure and investment accounts, with heavy cuts to personnel and a total hiring freeze for 7 years in technical-administrative roles that severely depleted the IT HR in a field of strong technological development; cuts were also made in the purchasing sector of ICT goods and services and their adaptation to new IT developments on which various spending review interventions were implemented. • The Covid-19 pandemic, which struck the Alessandria area with particular speed and severity starting in January 2020, given the close geographical proximity to the area of initial spread, brought further difficulties in managing the IT sector, which was called to the front line to face the pandemic emergency, slowing down the processes of adapting IT systems to higher levels of security desired by the company's strategic management for better protection of personal data. The Covid pandemic emergency has ceased, as per WHO provisions, on 5/5/2023"; - "despite this context of 'extraordinary' management, the company has managed, among other things, to launch an ambitious plan to redesign its IT infrastructure – information, starting as early as 2021, with significant investments in hardware, software, and human resources, with a strategic plan that sees digitalization and in the particular attention to cybersecurity as one of the foundational elements. The malicious hacker attack occurred at a time when this plan had been initiated and was in the process of implementation with the resources that were finally available (also thanks to the PNRR), resulting in the subsequent acceleration of the risk mitigation plan necessary in light of the development of technologies and data processing systems";

- "the notification of infiltration into the hospital network and the subsequent analysis of the vulnerabilities that allowed this event have sharply accelerated a series of changes whose necessity and urgency, especially concerning the configuration of the previous infrastructure, the Management was absolutely convinced of, and for which a path of profound restructuring and re-engineering was underway, with significant investments initiated. These activities have sought (...), not to limit themselves to the mere acquisition of technology, but, on the contrary, to start from the organizational dimension of cybersecurity, which is far more relevant than the technical one. Based on this awareness, the roles and access profiles to the network for operators have been clearly constructed, not only for technical-administrative staff but especially for healthcare professionals; the management rules have been defined according to which certain data can be conveyed only through certain channels (certified applications and not shared folders on the File Server, for example), a strong commitment mechanism has been activated by the Management as a whole (through the assignment of specific objectives in the Performance Plan to the entire organization), and not only by the person responsible for information systems, so that the response plan to vulnerabilities is not oriented towards emergencies, but the management of aspects of personal data security and privacy protection is an integral part of the work conduct of every employee."

6. Outcome of the investigative activity

Taking into account what was represented by the Company during the proceedings, it is observed that:

- “health-related data” is considered to be “personal data concerning the physical or mental health of a natural person, including the provision of health care services, which reveal information related to their health status” (art. 4, par. 1, n. 15, of the Regulation);
- personal data must be “processed in a manner that ensures adequate security (...) including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage” (principle of “integrity and confidentiality,” art. 5, par. 1, lett. f), of the Regulation);
- art. 32 of the Regulation, concerning the security of processing, establishes that “taking into account the state of the art and the costs of implementation, as well as the nature, subject matter, context and purposes of processing, and the risk of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk (...)” (par. 1) and that “in assessing the appropriate level of security, particular consideration shall be given to the risks presented by processing that arise in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored or otherwise processed” (par. 2).
- the “Guidelines 9/2022 on the notification of personal data breaches under the GDPR” adopted by the European Data Protection Board on March 28, 2023, further clarify that “the ability to identify, manage and report a breach promptly must be considered an essential aspect” of the technical and organizational measures that the controller and the processor must implement, pursuant to art. 32 of the Regulation, to ensure an adequate level of security for personal data;
- according to Recital no. 87, “it is appropriate to verify whether all appropriate technological and organizational protection measures have been implemented to immediately establish whether there has been a personal data breach and to promptly inform the supervisory authority and the data subject.”

7. Conclusions: declaration of unlawfulness of the processing.

In light of the above, it is noted that the processing carried out in the context in question requires the adoption of the highest security standards in order not to compromise the confidentiality, integrity, and availability of personal data of a very significant number of data subjects. This also takes into account the purposes of the processing and the nature of the personal data processed, which also belong to special categories and, in particular, to health data. In this regard, the security obligations provided by the Regulation impose the adoption of stringent technical and organizational measures, including, in addition to those expressly identified in art. 32, par. 1, lett. a) to d), all those necessary to mitigate the risks that the treatments present. Based on the evaluations mentioned above, taking into account the statements made by the data controller during the investigation and considering that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor," the elements provided by the data controller in the aforementioned defensive memorandum, although deserving of consideration, do not allow for overcoming the observations notified by the Office with the aforementioned initiation act of the procedure, nor do any of the cases provided for by Article 11 of the Guarantor's regulation no. 1/2019 apply.

From the examination of the information and elements acquired as well as the documentation provided, the treatment carried out by the Company is found to be unlawful, as it was carried out in violation of Articles 5, paragraph 1, letter f) and 32 of the Regulation, in relation to the aspects reported below.

7.1. Failure to adopt adequate measures to promptly detect personal data breaches

During the investigation, it emerged that malicious actors carried out a series of preparatory operations for the cyber attack and that "the Company did not have a log management system" (see minutes of XX, pages XX and XX and of XX, page XX). From the documentation on file, it is evident that "the management of the emergency after the attack required accelerating some of the measures subject to

[...] planning," with particular reference to the SIEM (Security Information and Event Management) to be connected to "external SOC's used as services to supplement the office hours in force at the service, in order to ensure 24/7 coverage of control, analysis, and support for remediation" (see attachment XX to the minutes of XX, page X). The highlighted deficiency did not allow the Company to detect and become promptly aware of the personal data breach that occurred.

The failure to adopt adequate measures to promptly detect personal data breaches does not comply with the provisions of Article 5, paragraph 1, letter f), and Article 32, paragraph 1, of the Regulation, which, in the case at hand, taking into account the provisions of the aforementioned Guidelines, requires that the data controller and the data processor must implement measures to "identify [...] promptly a breach."

7.2. Failure to adopt adequate measures to ensure network security and obsolescence of the base software installed on certain processing systems

During the investigation, it emerged that the Company had not adopted adequate measures to segment and segregate the networks on which the workstations of its employees were located, as well as the systems (servers) used for processing. In fact, as highlighted by the Company during the inspection activities, "the network was essentially flat, there was no logical or physical segmentation," and the workstations and servers were not differentiated at the network level (see minutes of XX, page XX and attachment XX to the minutes of XX, pages XX and XX).

Moreover, at the time when the personal data breach occurred, remote access, via VPN, to the Company's network was carried out through a computer authentication procedure based solely on the use of username and password. In relation to this aspect, the Company specified that "there was no multi-factor authentication (MFA) procedure for remote access via VPN. (...) The 'maintenance' accounts were often generic, not individual, with maximum administrative privileges," and that "although guidance had been provided to staff regarding password selection, inspired by good industry practices, there was no configuration of the systems that incorporated such guidance. Users performing administrative functions used differentiated accounts, depending on whether it was a personal domain account or an account with administrative privileges. In the latter case, the credentials, which did not have a specific password policy, were generally shared among different administrators" (see minutes of XX, page XX). In relation to this profile, the Company, following the incident, deemed it necessary to "activate MFA, certify the VPN, and identify named accounts (through specific forms), in compliance with the principle of 'least privilege.'"

During the investigation, it emerged that "it is presumed that the attacker may have exploited a vulnerability related to the perimeter firewall XX [and] that the version of the operating system of the firewall XX was vulnerable" and that "various obsolete communication protocols were still active." In relation to this aspect, the Company, following the incident, proceeded with the technological update of the devices and infrastructure.

The failure to implement, at the time of the breach, adequate measures to ensure network security and the use of obsolete base software, for which no longer available...

****Security updates**** do not appear to be fully compliant with the provisions of Article 5, paragraph 1, letter f), and Article 32, paragraph 1, of the Regulation, which, in this case, requires that the data controller and the data processor implement measures to "ensure on a permanent basis the confidentiality, integrity, availability, and resilience of processing systems and services" (letter b).

8. ****Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions**** (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The violation of Articles 5, paragraph 1, letter f) and 32 of the Regulation, caused by the conduct of the Company, results in the application of the administrative pecuniary sanction pursuant to Article 83, paragraphs 4 and 5 of the Regulation.

The Authority, pursuant to Article 58, paragraph 2, letter i) of the Regulation and Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition

to (other) corrective measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case,” by adopting an injunction order (Article 18 of Law No. 689 of November 24, 1981), in relation to the processing of personal data carried out by the Company, which has been found to be unlawful, as outlined above.

It is deemed necessary to apply paragraph 3 of Article 83 of the Regulation, which provides that “if, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this Regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation,” the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same Article 83, paragraph 5.

In light of the above and, in particular, of the category of personal data affected by the violation, which, by their nature, are particularly sensitive in terms of fundamental rights and freedoms, it is considered that the level of severity of the violation committed by the Company is high (cf. European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60), despite the unintentional nature of the violation (the incident appears to have been caused by fraudulent behavior on the part of a third party, formally reported to the postal police). That said, certain elements are evaluated as a whole, and in particular that:

- the Authority became aware of the event following the notification of the violation made by the Company, pursuant to Article 33 of the Regulation, and no complaints or reports regarding the violation subject to this provision have been received (Article 83, paragraph 2, letters h) and k) of the Regulation);
- the data controller, in order to prevent the recurrence of the event, has committed to introducing measures aimed at reducing the replicability of the event and has cooperated with the Authority at every stage of the investigation, including the inspection phase, in order to remedy the violation and mitigate its possible negative effects (Article 83, paragraph 2, letters c) and f) of the Regulation);
- the management of the pandemic emergency has necessitated strong involvement from the IT sector, resulting in a significant slowdown in the processes of system adaptation (Article 83, paragraph 2, letter k) of the Regulation).

In light of the above elements and the assessments made, it is deemed appropriate, in this specific case, to determine the amount of the pecuniary sanction at €25,000.00 (twenty-five thousand/00) for the violation of Articles 5 and 32 of the same Regulation, based on the principles of effectiveness, proportionality, and deterrence to which the Authority must adhere, pursuant to Article 83, paragraph 1, of the Regulation.

In this context, it is also deemed necessary, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019, to proceed with the publication of this section containing the injunction order on the Authority's website. This is in consideration of the type of personal data subject to unlawful processing and the number of affected individuals involved.

****FOR ALL THE ABOVE REASONS, THE AUTHORITY****

pursuant to Articles 57, paragraph 1, letter f) and 83 of the Regulation, finds the unlawfulness of the processing carried out by the Hospital-University Company SS. Antonio e Biagio and Cesare Arrigo, with legal headquarters in Alessandria, via Venezia, 16 – 15121 - C.F. – P.I. No. 01640560064, as stated in the reasoning, for the violation of Articles 5 and 32 of the Regulation;

****ORDERS****

pursuant to Article 58, paragraph 2, letter i) of the Regulation, the same Company, in the person of

****Legal Representative Pro Tempore**** is ordered to pay the sum of €25,000.00 (twenty-five thousand/00) as an administrative monetary penalty for the violation indicated in this provision.

****ORDERS****

the aforementioned Company to pay the sum of €25,000.00 (twenty-five thousand/00) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law No. 689/1981. It is noted that pursuant to Article 166, paragraph 8 of the Code, the offender retains the option to settle

the dispute by paying - always according to the methods indicated in the attachment - an amount equal to half of the imposed penalty within the term referred to in Article 10, paragraph 3, of Legislative Decree No. 150 of September 1, 2011, provided for the submission of the appeal as indicated below.

****PROVIDES****

- a) pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor No. 1/2019, the publication of the injunction order on the Guarantor's website;
- b) pursuant to Article 154-bis, paragraph 3 of the Code and Article 37 of the Regulation of the Guarantor No. 1/2019, the publication of this provision on the website of the Authority;
- c) pursuant to Article 17 of the Regulation of the Guarantor No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to file an appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, October 17, 2024

****THE PRESIDENT****

Stanzione

****THE RAPPORTEUR****

Ghiglia

****THE SECRETARY GENERAL****

Mattei